Récapitulatif Active Directory

1. L'essentiel en un coup d'œil

Élément	Valeur
Domaine / NetBIOS	killerbeer.local / KILLERBEER
Contrôleur de domaine	SRV-DC01 (Windows Server 2012 R2) — rôle AD DS + DNS
Niveau fonctionnel	Windows Server 2012 R2 (permet les politiques de mot de passe différenciées, PSO)
Responsable AD	Le Chargé AD (compte d'administration : adminit, dans OU_ADMIN\OU_ADMINS_T0)
Équipe	5 personnes : 2 développeurs (Krys, Cyrine) et 3 réseaux (Oumaima, Sylvère, Ophélia)
Principe d'organisation	Les OU servent à ranger et à appliquer les GPO. Les droits passent par les groupes (modèle AGDLP : Compte → Groupe Global → Groupe Domaine Local → Permission).
Règle d'or	Aucun droit donné directement à une personne : toujours via un groupe. Aucun compte normal dans « Admins du domaine ».

2. Les OU (unités d'organisation)

Une OU est un dossier de l'annuaire. Elle sert à ranger les objets et à choisir quelle GPO s'applique à qui.

OU	Parent	Contient	À quoi ça sert
OU_ADMIN	Racine	Sous-OU d'administration	Regroupe tout ce qui est administration et comptes techniques
OU_ADMINS_T0	OU_ADMIN	Compte adminit	Comptes d'administration AD, très protégés
OU_COMPTES_SERVICES	OU_ADMIN	svc_sqlserver, svc_sqlagent, svc_gitlab	Comptes techniques des services (pas des personnes)
OU_R&D	Racine	user.reseau01, 02, 03	Comptes des membres de l'équipe réseaux (profil équipe/IT, pas rôle métier)
OU_TEST	Racine	user.dev01, user.dev02	Comptes des membres de l'équipe développement (profil équipe/IT)
OU_PRODUCTION	Racine	À confirmer	Présente dans l'annuaire mais absente du plan corrigé : à documenter ou à supprimer
OU_SERVEURS	Racine	Sous-OU de serveurs	Serveurs membres du domaine (jamais le contrôleur de domaine)
OU_INFRA	OU_SERVEURS	Serveurs d'infrastructure	DNS/DHCP, services réseau (hors DC)
OU_BDD	OU_SERVEURS	Serveur SQL Server	Serveur de base de données

OU	Parent	Contient	À quoi ça sert
OU_GITLAB	OU_SERVEURS	Serveur GitLab si sous Windows	Hébergement du code (si machine Linux : pas d'objet AD)
OU_SUPERVISION	OU_SERVEURS	Serveur de journaux	Wazuh / ELK / Graylog
OU_VULNERABLE	OU_SERVEURS	Machine vulnérable (si fournie)	Isolée pour l'audit de la phase 2
OU_POSTES	Racine	Sous-OU de postes	Ordinateurs clients Windows 10
OU_RD (postes)	OU_POSTES	PC de l'équipe R&D	GPO propres aux postes R&D
OU_TEST (postes)	OU_POSTES	PC de l'équipe test	GPO propres aux postes de test
OU_ADMIN (postes)	OU_POSTES	PC d'administration	Postes utilisés pour administrer
OU_GROUPES	Racine	Sous-OU de groupes	Rangement de tous les groupes
OU_GG_IT	OU_GROUPES	GG_RESEAUX, GG_DEV, GG_ADMIN	Groupes « équipe »
OU_GG_METIER	OU_GROUPES	GG_ROLE_*, GG_SQL_*	Groupes « rôle métier » et SQL
OU_DL_RESSOURCES	OU_GROUPES	DL_FS_*, DL_SQL_*	Groupes qui donnent l'accès aux ressources (partages, SQL)
Domain Controllers	Racine (native)	SRV-DC01	OU créée par Windows : ne jamais la modifier, ni y lier de GPO

Attention : OU_TEST et OU_ADMIN existent deux fois (racine = comptes utilisateurs, sous OU_POSTES = ordinateurs). Ce sont des objets différents : toujours vérifier le parent.

3. Comptes utilisateurs

Compte	Personne	OU	Groupe équipe	Rôle métier simulé	Remarque
cyrine.dev01	Cyrine	OU_TEST	GG_DEV	GG_ROLE_RD (R&D)	Crée modèles, ingrédients, procédés
krys.dev02	Krys	OU_TEST	GG_DEV	GG_ROLE_TEST (Test)	Exécute et valide les tests
ophelia.reseau01	Ophelia	OU_R&D	GG_RESEAUX	GG_ROLE_PROD (Usine)	Lecture seule sur le référentiel validé
oumaima.reseau02	Oumaima	OU_R&D	GG_RESEAUX	Aucun	Infrastructure
sylvere.reseau03	Sylvère	OU_R&D	GG_RESEAUX	Aucun	Infrastructure
adminit	Chargé AD	OU_ADMIN\OU_ADMINS_T0	GG_ADMIN	—	Administration uniquement, à ne pas utiliser au quotidien

Les rôles R&D / Test / Production sont simulés pour l'exercice : ils ne correspondent pas à la vraie fonction des personnes. Tous les comptes doivent changer leur mot de passe à la première connexion.

4. Comptes de service

Compte	Rôle	OU	Règles
svc_sqlserver	Fait tourner le service SQL Server	OU_COMPTES_SERVICES	Mot de passe long, n'expire pas, aucun groupe d'administration, pas de session interactive
svc_sqlagent	Fait tourner SQL Server Agent	OU_COMPTES_SERVICES	Idem, droits distincts de svc_sqlserver
svc_gitlab	Lien LDAP GitLab ↔ AD (seulement si nécessaire)	OU_COMPTES_SERVICES	Lecture seule sur l'annuaire

5. Groupes

Groupes globaux « équipe » (OU_GG_IT)

Groupe	Type	Membres	Utilité
GG_RESEAUX	Global, sécurité	user.reseau01, 02, 03	Cibler les GPO et délégations de l'équipe réseau
GG_DEV	Global, sécurité	user.dev01, user.dev02	Cibler les GPO et l'accès GitLab de l'équipe dev
GG_ADMIN	Global, sécurité	adminit	Administrateurs autorisés (délégation, RDP serveurs)

Groupes globaux « rôle métier » (OU_GG_METIER)

Groupe	Type	Membres	Utilité
GG_ROLE_RD	Global, sécurité	user.dev01	Rôle R&D → rôle SQL role_rd, schéma SCH_RD
GG_ROLE_TEST	Global, sécurité	user.dev02	Rôle Test → rôle SQL role_test, schéma SCH_TEST
GG_ROLE_PROD	Global, sécurité	user.reseau01	Rôle Usine, lecture seule → role_prod, schéma SCH_PROD
GG_SQL_DBA	Global, sécurité	Vide pour l'instant	Administrateurs SQL autorisés
GG_SQL_BCK	Global, sécurité	Vide pour l'instant	Opérateurs de sauvegarde SQL

Groupes de domaine local (OU_DL_RESSOURCES)

Groupe	Type	Membre (un groupe global)	Droit donné
DL_FS_RD_Modify	Domaine local, sécurité	GG_ROLE_RD	Modifier le partage R&D
DL_FS_TEST_Modify	Domaine local, sécurité	GG_ROLE_TEST	Modifier le partage Test
DL_FS_PROD_Read	Domaine local, sécurité	GG_ROLE_PROD	Lire le partage Production
DL_SQL_Admin	Domaine local, sécurité	GG_SQL_DBA	Droits d'administration SQL

Groupe	Type	Membre (un groupe global)	Droit donné
DL_SQL_Backup	Domaine local, sécurité	GG_SQL_BCK	Droits de sauvegarde SQL

6. La chaîne d'accès (AGDLP)

Compte	Groupe global	Groupe local	Droit final
user.dev01 (Krys)	GG_ROLE_RD	DL_FS_RD_Modify	Modification du partage R&D
user.dev02 (Cyrine)	GG_ROLE_TEST	DL_FS_TEST_Modify	Modification du partage Test
user.reseau01 (Oumaima)	GG_ROLE_PROD	DL_FS_PROD_Read	Lecture seule du partage Production

7. Politiques de mots de passe

Politique	S'applique à	Paramètres principaux	Remarque
Default Domain Policy	Tous les comptes du domaine	12 caractères, complexité, historique 12, verrouillage 5 essais / 15 min	Configurée dans gpmc.msc
PSO_ADMIN (priorité 10)	GG_ADMIN	14 caractères, historique 24, verrouillage 3 essais / 30 min, durée 60 jours	Plus strict pour les admins
PSO_SERVICE (priorité 20)	Comptes svc_*	20 caractères, historique 24, pas de verrouillage, n'expire pas	Absence de verrouillage à justifier dans le rapport et à compenser par la surveillance des journaux

Une PSO se lie à des groupes ou des utilisateurs, jamais à une OU.

8. GPO (stratégies de groupe)

GPO	Liée à	Objectif	Fait ?
GPO-Audit-Avance	OU de test, puis domaine	Journaliser ouvertures de session, gestion des comptes, modifications de stratégie	oui
GPO-Postes-Base	OU_POSTES	Pare-feu actif, verrouillage écran (10 min), compte Invité désactivé	oui
GPO-Postes-RD	OU_POSTES\OU_RD	Lecteur réseau du partage R&D	oui
GPO-Postes-TEST	OU_POSTES\OU_TEST	Lecteur réseau du partage Test	oui
GPO-Serveurs-Membres	OU_SERVEURS	Pare-feu, RDP limité à GG_ADMIN (jamais sur les DC)	oui

GPO	Liée à	Objectif	Fait ?
GPO-Admins-T0	OU_ADMIN\OU_ADMINS_T0	Restrictions renforcées des comptes admin (tester avant)	oui
GPO-Comptes-Service	OU_ADMIN\OU_COMPTES_SERVICES	Interdire la session interactive aux svc_*, autoriser « ouvrir une session en tant que service »	oui
GPO-WiFi	OU_POSTES	Profil Wi-Fi « Interne » côté poste (le SSID/VLAN se règlent sur la borne et l'UTM)	oui

9. Délégation d'administration

Sur quelle OU	Qui reçoit la délégation	Droits délégués
OU_R&D (racine)	GG_ADMIN	Réinitialiser les mots de passe, créer/supprimer/gérer les comptes utilisateurs
OU_TEST (racine)	GG_ADMIN	Idem

10. Ce que l'équipe doit retenir

- Pour vous connecter sur un poste : KILLERBEER\user.xxx (ex. KILLERBEER\user.dev01). Mot de passe à changer au premier login.
- Seuls les membres de « Admins du domaine » peuvent ouvrir une session sur le contrôleur de domaine : c'est normal que les autres soient refusés.
- Un droit se demande au Chargé AD via un groupe, jamais en ajoutant une personne directement sur une ressource.
- Ne jamais écrire de mot de passe, d'IP ou de nom de compte de service dans le tableau Kanban partagé.
- Tout changement dans l'AD (nouvelle OU, GPO, groupe) doit être annoncé au Chargé AD pour rester cohérent avec le schéma du livrable.
- Ces éléments serviront en phase 3 (traces dans les journaux AD) et en phase 4 (remédiation des failles trouvées par l'autre équipe).